<u>สอบปลายภาค วิชา เวชระเบียนศาสตร์</u>

นายธนดล ศรีปัญญา 671424005003-9 เทคโนโลยีสารสนเทศทางการแพทย์ชั้นปีที่ 2

<u>ข้อที่ 1</u>: ข้อสอบข้อเขียน (วัดความเข้าใจในระบบเวชระเบียนและกฎหมาย) คะแนนเต็ม: 20 คะแนน (เวลาทำข้อสอบ 45 นาที)

โจทย์ (Case Study): โรงพยาบาลมหาวิทยาลัยกาฬสินธุ์ กำลังอยู่ในช่วงเปลี่ยนผ่านจากการเก็บประวัติผู้ป่วยด้วยกระดาษ (Paper-based) ไปสู่ระบบเวชระเบียนอิเล็กทรอนิกส์ (EMR) แบบ 100% เพื่อรองรับการเป็นศูนย์กลางทางการแพทย์และการศึกษาในภูมิภาค รวมถึงเตรียมพร้อมสำหรับการแลกเปลี่ยนข้อมูลสุขภาพกับสถานพยาบาลเครือข่าย (Interoperability) แต่ทางผู้บริหารยังมีความกังวลเรื่องความปลอดภัยของข้อมูล ในฐานะที่คุณเป็น "นักเทคโนโลยีสารสนเทศทางการแพทย์" ที่รับผิดชอบโครงการนี้ ให้อธิบายและวิเคราะห์ประเด็นต่อไปนี้ให้ชัดเจน:

1.จงเสนอแนะว่าระบบ EMR ใหม่ของโรงพยาบาลมหาวิทยาลัยกาฬสินธุ์ ควรใช้มาตรฐานการจัดเก็บและแลกเปลี่ยนข้อมูลประเภทใดบ้าง (เช่น รหัสโรค, มาตรฐานการส่งต่อข้อมูล) พร้อมอธิบายเหตุผลสั้นๆ ว่าแต่ละมาตรฐานมีความสำคัญอย่างไรต่อการทำงานของแพทย์และการเบิกจ่าย (10 คะแนน)

2.จาก พ.ร.บ. คุ้มครองข้อมูลส่วนบุคคล (PDPA) และความเสี่ยงด้านไซเบอร์ (เช่น Ransomware) จงยกตัวอย่างความเสี่ยงที่อาจเกิดขึ้นกับระบบ EMR ของโรงพยาบาลมา 2 ข้อ พร้อมเสนอแนวทางเชิงเทคนิคหรือการออกแบบระบบ (System Design) เพื่อป้องกันความเสี่ยงเหล่านั้น (10 คะแนน)

📌 เกณฑ์การให้คะแนน (Rubric) ข้อ 1: อ้างอิงมาตรฐานได้ถูกต้อง (เช่น ICD-10, HL7/FHIR) และเชื่อมโยงกับการเบิกจ่ายหรือการรักษาในบริบทโรงพยาบาลมหาวิทยาลัยได้สมเหตุสมผล มองเห็นความเสี่ยงด้าน Privacy/Security ได้เฉียบคม และเสนอวิธีการแก้ปัญหาทาง IT ที่ทำได้จริง (เช่น การกำหนด Role-based Access Control, การทำ Data Encryption หรือ Backup แบบ Offline)

<u>คำตอบส่วนที่ 1</u>

<u>กลุ่มที่ 1: มาตรฐานรหัสและคำศัพท์ทางคลินิก (Terminology & Classification Standards)</u>

เป็นมาตรฐานสำหรับ "บันทึกข้อมูล" เพื่อให้คอมพิวเตอร์เข้าใจความหมายเดียวกับที่แพทย์เข้าใจ และเป็นหัวใจหลักของรายได้โรงพยาบาล

1. ICD-10 (International Classification of Diseases) หรืออนาคตคือ ICD-11

- **ความสำคัญต่อแพทย์:** เป็นมาตรฐานสากลในการลงรหัส "การวินิจฉัยโรค" ทำให้แพทย์และนักศึกษาแพทย์สามารถสืบค้นประวัติผู้ป่วยเพื่อทำวิจัยทางระบาดวิทยา หรือดูสถิติโรคในระดับภูมิภาคได้ง่าย
- **ความสำคัญต่อการเบิกจ่าย:** เป็นตัวแปรหลักที่สุดในการคำนวณ **กลุ่มวินิจฉัยโรคร่วม (DRGs)** เพื่อใช้เรียกเก็บเงิน (e-Claim) จากกองทุนต่างๆ เช่น สปสช. (บัตรทอง), ประกันสังคม และกรมบัญชีกลาง หากรหัสผิด โรงพยาบาลจะขาดทุนทันที

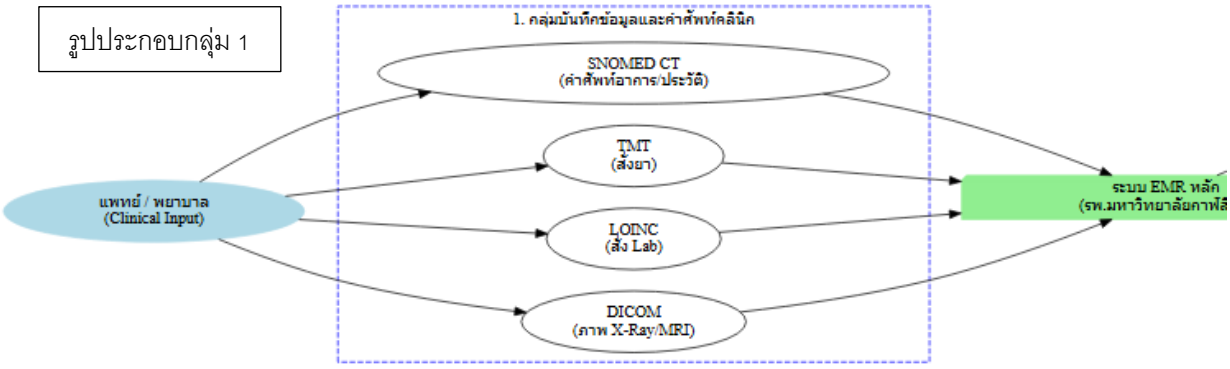
2. ICD-9-CM หรือ ICD-10-TM (Thai Modification)

- **ความสำคัญต่อแพทย์:** ใช้บันทึก "รหัสหัตถการและการผ่าตัด" ทำให้ทราบประวัติการรักษาที่ผู้ป่วยเคยได้รับอย่างชัดเจน
- **ความสำคัญต่อการเบิกจ่าย:** เป็นอีกหนึ่งตัวแปรสำคัญที่ใช้ร่วมกับ ICD-10 เพื่อเพิ่มค่าน้ำหนักสัมพัทธ์ (Relative Weight - RW) ในระบบ DRGs ทำให้โรงพยาบาลเบิกจ่ายค่าผ่าตัดหรือหัตถการที่มีความซับซ้อนสูงได้ตรงตามต้นทุนจริง

3. SNOMED CT (Systematized Nomenclature of Medicine - Clinical Terms)

- **ความสำคัญต่อแพทย์:** เป็นมาตรฐานคำศัพท์คลินิกที่มีความละเอียดสูงมาก (Granularity) ช่วยให้แพทย์บันทึก อาการ, ประวัติครอบครัว, หรือผลการตรวจร่างกายได้ลึกซึ้ง เหมาะมากสำหรับการเป็น **โรงพยาบาลมหาวิทยาลัย** ที่ต้องการนำข้อมูลไปใช้ฝึกระบบ AI หรือ Clinical Decision Support System (ระบบช่วยตัดสินใจทางคลินิก)
- **ความสำคัญต่อการเบิกจ่าย:** แม้ไม่ได้ใช้เบิกจ่ายโดยตรง แต่ระบบ EMR ที่ดีจะทำ Mapping (จับคู่) จาก SNOMED CT ไปเป็น ICD-10 อัตโนมัติ ช่วยลดภาระ Coder (ผู้ให้รหัส) และป้องกันการตกหล่นของข้อมูลเพื่อการเบิกจ่าย

รูปประกอบกลุ่ม 1



<u>**กลุ่มที่ 2: มาตรฐานข้อมูลเฉพาะระบบ (Domain-Specific Standards)**</u>

สำหรับการจัดการข้อมูลเฉพาะทาง เช่น ยา ห้องปฏิบัติการ และภาพถ่ายทางการแพทย์

4. TMT (Thai Medicines Terminology) - **รหัสยามาตรฐานไทย**

- **ความสำคัญต่อแพทย์:** ทำให้แพทย์สั่งยา (CPOE) ได้อย่างถูกต้อง ป้องกันความผิดพลาด (Medication Error) และระบบสามารถแจ้งเตือนการแพ้ยาข้ามโรงพยาบาลได้หากเครือข่ายใช้มาตรฐานเดียวกัน
- **ความสำคัญต่อการเบิกจ่าย:** เป็นมาตรฐานที่กระทรวงสาธารณสุขบังคับใช้ การส่งเบิกรายการยาเพื่อขอรับเงินคืนจากกองทุนในประเทศไทย **ต้อง** ใช้รหัส TMT เป็นโครงสร้างหลัก

5. LOINC (Logical Observation Identifiers Names and Codes)

- **ความสำคัญต่อแพทย์:** เป็นมาตรฐานสากลสำหรับ "รหัสผลตรวจทางห้องปฏิบัติการ (Lab)" เมื่อผู้ป่วยถูกส่งต่อมาจากสถานพยาบาลเครือข่าย แพทย์มหาวิทยาลัยกาฬสินธุ์สามารถดูกราฟแนวโน้มผล Lab (เช่น ค่าน้ำตาล HbA1c) ได้ทันที โดยไม่ต้องเจาะเลือดใหม่
- **ความสำคัญต่อการเบิกจ่าย:** ลดความซ้ำซ้อนและต้นทุนในการตรวจ Lab ที่ไม่จำเป็น และใช้เป็นหลักฐานประกอบการเบิกจ่ายค่าตรวจทางห้องปฏิบัติการราคาแพง

6. DICOM (Digital Imaging and Communications in Medicine)

- **ความสำคัญต่อแพทย์:** มาตรฐานสำหรับ "ภาพถ่ายทางการแพทย์" (X-Ray, MRI, CT Scan) ช่วยให้แพทย์ดูภาพความละเอียดสูงผ่านระบบ PACS ที่ฝังอยู่ใน EMR ได้ทันที
- **ความสำคัญต่อการเบิกจ่าย:** ใช้เป็นหลักฐานดิจิทัลยืนยันว่ามีการทำหัตถการด้านรังสีวิทยาจริง เพื่อประกอบการเบิกจ่าย

<u>กลุ่มที่ 3: มาตรฐานการแลกเปลี่ยนและส่งต่อข้อมูล (Interoperability Standards)</u>

เพื่อตอบโจทย์การเป็นศูนย์กลาง (Hub) ที่ต้องคุยกับโรงพยาบาลระดับจังหวัด อำเภอ และ รพ.สต.

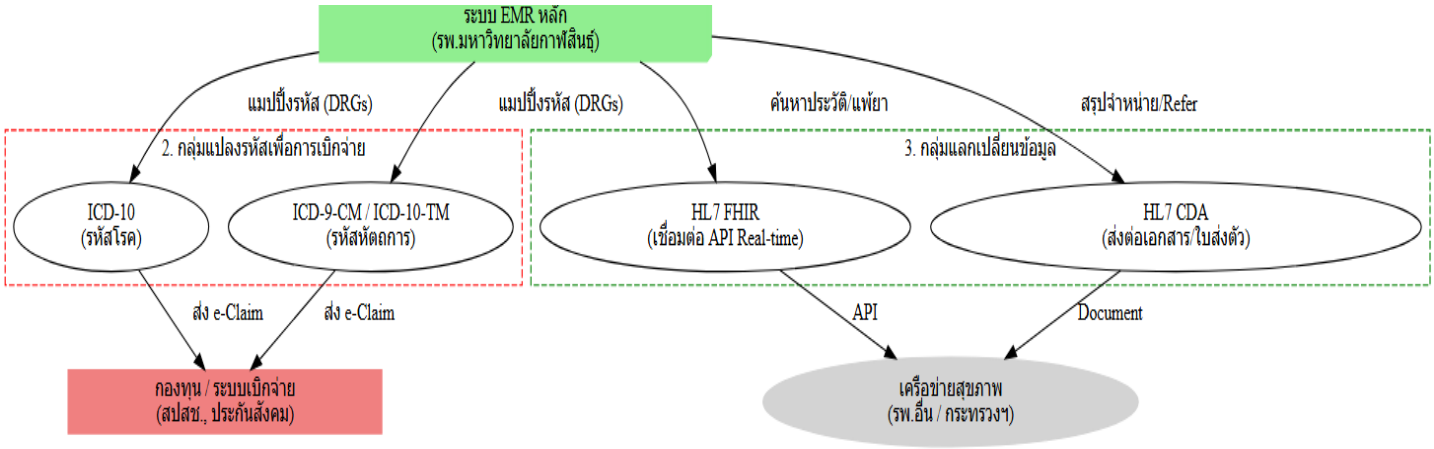
7. HL7 FHIR (Fast Healthcare Interoperability Resources)

- **ความสำคัญต่อแพทย์:** เป็นมาตรฐานการแลกเปลี่ยนข้อมูลแบบ API ที่ทันสมัยที่สุดในโลกปัจจุบัน ช่วยให้ EMR ของ รพ.มหาวิทยาลัย สามารถ "ดูดข้อมูล" ประวัติการรักษา, การแพ้ยา, หรือวัคซีน จากโรงพยาบาลอื่นมาแสดงบนหน้าจอของแพทย์ได้แบบ Real-time (ไร้รอยต่อ)
- **ความสำคัญต่อการเบิกจ่าย:** รองรับระบบ e-Referral (การส่งต่อผู้ป่วยอิเล็กทรอนิกส์) ทำให้การติดตามค่าใช้จ่ายและการเรียกเก็บเงินระหว่างโรงพยาบาลต้นทางและปลายทาง (Clearing House) ทำได้รวดเร็วและตรวจสอบได้ง่ายขึ้น

8. HL7 CDA (Clinical Document Architecture)

- **ความสำคัญต่อแพทย์:** เป็นมาตรฐานโครงสร้าง "เอกสารทางคลินิก" เช่น ใบสรุปจำหน่ายผู้ป่วย (Discharge Summary) ทำให้เอกสารที่ส่งข้ามโรงพยาบาลสามารถอ่านได้ทั้งโดยคนและคอมพิวเตอร์ประมวลผลได้
- **ความสำคัญต่อการเบิกจ่าย:** ใช้เป็นหลักฐานอิเล็กทรอนิกส์ (Electronic Medical Record Evidence) ที่ได้มาตรฐานทางกฎหมาย เมื่อมีการตรวจสอบย้อนหลัง (Audit) จากหน่วยงานผู้จ่ายเงิน
-

รูปประกอบกลุ่ม 2 และ 3



<u>คำตอบส่วนที่ 2</u>

<u>ความเสี่ยงที่ 1: การละเมิดข้อมูลส่วนบุคคลโดยบุคลากรภายใน (PDPA / Insider Threat)</u>

ลักษณะความเสี่ยง: โรงพยาบาลมหาวิทยาลัยมีการเรียนการสอน ทำให้มีนักศึกษาแพทย์ แพทย์ประจำบ้าน และเจ้าหน้าที่จำนวนมากหมุนเวียนเข้ามา ความเสี่ยงคือ **การเข้าถึงเวชระเบียนของผู้ป่วยโดยไม่มีหน้าที่เกี่ยวข้องกับการรักษา (Unauthorized Access / Snooping)** เช่น แอบดูประวัติการรักษาของบุคคลที่มีชื่อเสียง หรือนำข้อมูลผู้ป่วยไปใช้ทำวิจัยโดยไม่ได้ทำการขอความยินยอม (Consent) และไม่ได้ปิดบังตัวตน ซึ่งเป็นการละเมิด พ.ร.บ. คุ้มครองข้อมูลส่วนบุคคล (PDPA) อย่างร้ายแรง

แนวทางเชิงเทคนิคและการออกแบบระบบ (System Design):

- **ออกแบบระบบสิทธิ์การเข้าถึงแบบ Role-Based Access Control (RBAC):** กำหนดสิทธิ์ให้ผู้ใช้งานเห็นข้อมูลเท่าที่จำเป็นตาม "บทบาท" และ "ความรับผิดชอบในขณะนั้น" เช่น นักศึกษาแพทย์จะเปิดดูประวัติได้เฉพาะเคสที่ตนเองได้รับมอบหมาย (Assigned Cases) เท่านั้น และแพทย์ทั่วไปจะไม่สามารถเข้าถึงแฟ้มประวัติจิตเวชได้หากไม่ใช่แพทย์เจ้าของไข้
- **ระบบการบันทึกร่องรอย (Immutable Audit Logs) และแจ้งเตือนอัตโนมัติ:** ระบบ EMR ต้องบันทึกทุก Transaction ว่า ใคร (User ID) ทำอะไร (View/Edit/Export) กับข้อมูลของใคร (Patient ID) เมื่อไหร่ (Timestamp) และจากเครื่องไหน (IP Address) โดย Log นี้ต้องถูกตั้งค่าไม่ให้ใครลบหรือแก้ไขได้ หากมีการดึงข้อมูลผู้ป่วยจำนวนมากผิดปกติ ระบบจะส่ง Alert แจ้งเตือนไปยัง IT Security ทันที
- **การทำข้อมูลให้เป็นนิรนาม (Data Anonymization / Masking):** หากแพทย์หรือนักศึกษาต้องการดึงข้อมูลไปใช้เพื่อการศึกษาหรือวิจัย ระบบจะต้องมีฟีเจอร์ Masking ซ่อนชื่อ นามสกุล เลขบัตรประชาชน หรือแปลงเป็นรหัสสมมติโดยอัตโนมัติก่อน Export ข้อมูลออกจากระบบ

<u>ความเสี่ยงที่ 2: การโจมตีด้วยมัลแวร์เรียกค่าไถ่เพื่อหยุดการทำงานของระบบ (Ransomware Attack)</u>

ลักษณะความเสี่ยง: แฮกเกอร์ส่งอีเมลหลอกลวง (Phishing) ให้เจ้าหน้าที่ในโรงพยาบาลเผลอกดคลิกลิงก์ ส่งผลให้ Ransomware เจาะเข้าสู่เครือข่ายภายในและทำการ **เข้ารหัส (Encrypt) ฐานข้อมูล EMR ทั้งหมด** ทำให้แพทย์ไม่สามารถเปิดดูประวัติผู้ป่วย ดูผล Lab หรือสั่งยาได้ ระบบโรงพยาบาลจะกลายเป็นอัมพาต และอาจเป็นอันตรายถึงชีวิตผู้ป่วย (Patient Safety) หากกู้ระบบไม่ได้หรือผู้บริหารไม่ยอมจ่ายค่าไถ่

แนวทางเชิงเทคนิคและการออกแบบระบบ (System Design):

- **สถาปัตยกรรมเครือข่ายแบบแยกส่วน (Network Segmentation):** ออกแบบระบบเครือข่าย (VLAN) แยกส่วนกันอย่างเด็ดขาดระหว่าง โซนผู้ใช้งานทั่วไป (แผนกต้อนรับ, Back office), โซนอุปกรณ์การแพทย์ (Medical IoT), และ โซนเซิร์ฟเวอร์ฐานข้อมูล EMR (Core Servers) เพื่อจำกัดวงความเสียหาย (Blast Radius) ไม่ให้ Ransomware ลามจากเครื่องคอมพิวเตอร์ทั่วไปเข้าสู่เซิร์ฟเวอร์หลักได้ง่าย
- **กลยุทธ์การสำรองข้อมูลแบบ 3-2-1 และ Immutable Backup:** ออกแบบระบบ Backup ให้มีข้อมูลสำรองอย่างน้อย 3 ชุด เก็บไว้ในสื่อ (Media) 2 ประเภทที่ต่างกัน และ **1 ชุดต้องเก็บแบบ Offline หรือ Immutable Storage** (ระบบจัดเก็บแบบเขียนได้ครั้งเดียว อ่านได้อย่างเดียว) ซึ่ง Ransomware จะไม่สามารถเข้าไปลบหรือเข้ารหัสข้อมูลสำรองชุดนี้ได้ ทำให้เรามั่นใจว่ามีข้อมูลสะอาดพร้อมกู้คืนระบบ (Disaster Recovery) ได้เสมอ
- **การติดตั้งระบบ EDR (Endpoint Detection and Response):** ติดตั้งซอฟต์แวร์ตรวจจับพฤติกรรมต้องสงสัยที่เครื่องคอมพิวเตอร์ทุกเครื่องในโรงพยาบาล หากระบบพบกระบวนการที่พยายามเข้ารหัสไฟล์จำนวนมาก EDR จะตัดการเชื่อมต่อเครื่องนั้นออกจากเครือข่ายทันทีก่อนที่มัลแวร์จะกระจายตัว

<u>ข้อที่ 2</u>: ข้อสอบปฏิบัติ (วัดทักษะฐานข้อมูลและ UI/UX สำหรับโรงพยาบาลมหาวิทยาลัย) คะแนนเต็ม: 30 คะแนน (เวลาทำข้อสอบ 1 ชั่วโมง 15 นาที)

โจทย์ (Practical Task): ระบบสารสนเทศโรงพยาบาล (HIS) ของ โรงพยาบาลมหาวิทยาลัยกาฬสินธุ์ มีการจัดเก็บข้อมูลที่ต้องรองรับทั้งการรักษาผู้ป่วยและการเรียนการสอนของนักศึกษาแพทย์ สมมติว่าคุณได้รับสิทธิ์เข้าถึงฐานข้อมูลจำลอง ซึ่งประกอบด้วย 3 ตาราง (Tables) หลัก ดังนี้:

1.Patient_Data (ข้อมูลผู้ป่วย): HN, FirstName, LastName, DOB, District (อำเภอ)

2.Visit_Log (ประวัติการเข้ารับบริการ): VN, HN, VisitDate, Clinic_Name (เช่น 'คลินิกอายุรกรรม', 'คลินิกศัลยกรรม')

3.Diagnosis_Record (ข้อมูลการวินิจฉัย): VN, ICD10_Code, Attending_Doctor (อาจารย์แพทย์ผู้ดูแล), Med_Student (นักศึกษาแพทย์ผู้ตรวจเบื้องต้น)

ภารกิจของคุณคือ:

1. (15 คะแนน) SQL Query สำหรับคัดกรองข้อมูลเพื่อการวิจัยและติดตามโรค: โรงพยาบาลต้องการทำโครงการวิจัยเพื่อติดตามผู้ป่วยโรคเบาหวานในพื้นที่จังหวัดกาฬสินธุ์ จงเขียนคำสั่ง SQL เพื่อดึงข้อมูล ได้แก่ ชื่อ-นามสกุลผู้ป่วย, วันที่เข้ารับการรักษา, รหัสการวินิจฉัยโรค (ICD-10) และชื่ออาจารย์แพทย์ผู้ดูแล
***เงื่อนไขบังคับ: ต้องดึงเฉพาะผู้ป่วยที่ได้รับการวินิจฉัยในกลุ่มโรคเบาหวาน (รหัส ICD-10 ขึ้นต้นด้วย E11) ที่เข้ามารับบริการที่ 'คลินิกอายุรกรรม' ในช่วงวันที่ 1 มกราคม ถึง 31 มีนาคม ของปีปัจจุบัน และเรียงลำดับผลลัพธ์ตามวันที่เข้ารับบริการจากล่าสุดไปเก่าที่สุด

2. (15 คะแนน) UI/UX Design สำหรับอาจารย์แพทย์และนักศึกษาแพทย์: จากข้อมูลเวชระเบียนที่ดึงมาได้ ให้ออกแบบหน้าจอจำลอง (Wireframe / Mock-up สามารถวาดลงกระดาษ หรือใช้เครื่องมือออกแบบตามที่อาจารย์กำหนด) สำหรับ "EMR Teaching Dashboard" (หน้าจอเวชระเบียนสำหรับการเรียนการสอน) เพื่อใช้งานในห้องตรวจของโรงพยาบาลมหาวิทยาลัยกาฬสินธุ์
***เงื่อนไขบังคับ: * ต้องมีส่วนที่แสดงข้อมูลผู้ป่วย (Patient Profile) และประวัติโรคประจำตัว ต้องมีฟังก์ชันที่แสดง "บันทึกการตรวจของนักศึกษาแพทย์" แยกกับ "บันทึกและคำสั่งรักษาของอาจารย์แพทย์" อย่างชัดเจน ต้องออกแบบโดยยึดหลัก UI/UX ที่ดี ช่วยลดความซับซ้อน (Minimize Clicks) และลดความผิดพลาดในการสั่งยา (Medication Error) พร้อมเขียนอธิบายแนวคิดการออกแบบหน้าจอนี้สั้นๆ (ประมาณ 3-5 บรรทัด)

📌 เกณฑ์การให้คะแนน (Rubric)

ข้อ 1: ส่วน SQL (15 คะแนน): * ใช้คำสั่ง SELECT, FROM และ JOIN ตารางทั้ง 3 ได้ถูกต้องตามหลัก RDBMS (5 คะแนน) ใช้เงื่อนไข WHERE ร่วมกับ LIKE (สำหรับ E11%) และกำหนดช่วงวันที่ได้ถูกต้อง (5 คะแนน) ใช้คำสั่ง ORDER BY เรียงลำดับวันที่ได้ถูกต้อง (5 คะแนน)

ข้อ 2 : ส่วน UI/UX (15 คะแนน): * จัดวาง Information Architecture ได้เป็นระเบียบ อ่านง่าย เหมาะกับการใช้งานในห้องตรวจที่เร่งรีบ (5 คะแนน) ตอบโจทย์การใช้งานของ 2 บทบาท (อาจารย์แพทย์ และ นักศึกษาแพทย์) ในหน้าจอเดียวได้จริง (5 คะแนน)

<u>คำตอบส่วนที่ 1</u>

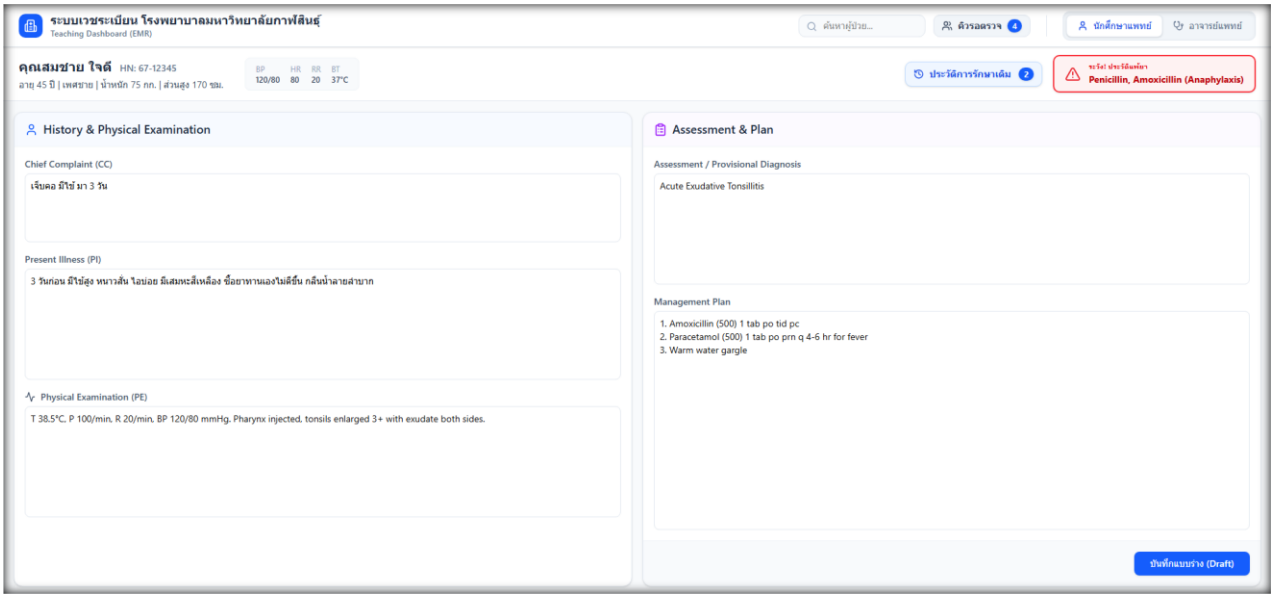
SQL

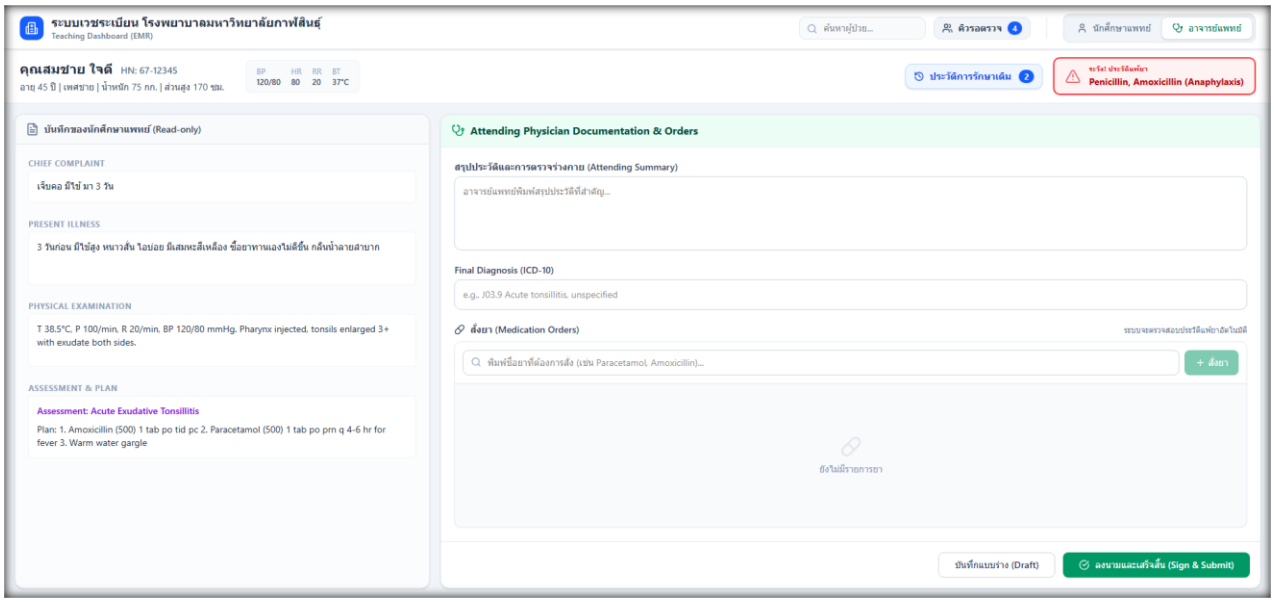
```sql
SELECT
    p.FirstName,
    p.LastName,
    v.VisitDate,
    d.ICD10_Code,
    d.Attending_Doctor
FROM
    Patient_Data p
JOIN
    Visit_Log v ON p.HN = v.HN
JOIN
    Diagnosis_Record d ON v.VN = d.VN
WHERE
    d.ICD10_Code LIKE 'E11%'
    AND v.Clinic_Name = 'คลินิกอายุรกรรม'
    AND v.VisitDate BETWEEN '2026-01-01' AND '2026-03-31'
ORDER BY
    v.VisitDate DESC;
```

FirstName	LastName	VisitDate 1	ICD10_Code	Attending_Doctor
ใจดี	รักษาดี	2026-03-05	E11.2	อ.นพ. สมเกียรติ
ใจดี	รักษาดี	2026-02-15	E11.9	อ.นพ. สมเกียรติ

คำตอบส่วนที่ 2

Dashboard ของนักศึกษาแพทย์ ซึ่งสามารถกดสลับกับ Dashboard แพทย์ได้





ออกแบบด้วยแนวคิด Single-page Dashboard ที่มีประวัติการตรวจและแผนการรักษาในหน้าเดียว ช่วยลดการคลิกสลับหน้าและยังมีการแสดงข้อมูลพื้นฐานผู้ป่วยข้างบนที่สามารถดูประวัติการให้ยาเดิม มีปุ่มสลับบทบาทด้านบนเพื่อแยกการทำงานของนักศึกษาและอาจารย์แพทย์ชัดเจน จุดเด่นคือการตรึงแถบเตือนประวัติแพ้ยาสีแดง (Allergy Alert) ไว้บนสุด เพื่อให้ระบบสามารถตัดเตือนได้ทันทีหากสั่งยาที่แพ้ เพื่อช่วยลด Medication Error และหากดูในหน้าของอาจารย์ก็จะเห็นสิ่งที่นักศึกษาบันทึกและตัดสินใจในขั้นสุดท้ายได้